TREPATH 2.2 - Penetration Testing Report

Authorized Assessment Scope (owasp.org (+13 authorized origins across 14 in-scope assets)) | TrePath 2.2 + EvidenceCore Provenanc

Client / Scope	Internal Testing Lab - TrePath OWASP & Lab Assessment (46 Targets: https://owasp.org/projects/juice-shop +45) (owasp.org (+13 authorized origins across 14 in-scope assets))
Scan Execution Window	Executed: 2026-11-02 00:18:44 UTC | Report Rendered: 2026-11-02 10:40 UTC (Scan #39 | Profile: authorized_pentest)
Assessment Engine	TrePath 2.2 Autonomous Scope Provenance, Proof Validation, EvidenceCore & AttackGraph Engine
Document Classification	CONFIDENTIAL - Executive, Technical & Cryptographic Deliverable
T0 Baseline Calibrated Risk	MEDIUM (4.4 / 10 | 44.3 / 100 Calibrated 7-Dimension Risk Index)
T1 Post-Retest Verified Risk	0 Executed Retests Recorded in RTEX Ledger (Ready for Live Closure Verification)
Hypothetical SLA Forecast	Projected Post-Hardening Risk: 2.1 / 10 (LOW) upon completion of prioritized remediation work packages
Verified Compromise / Admin Auth Status	0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 0 IMPACT_VERIFIED Safe PoCs
Host Scope Reconciliation	14 Authorized In-Scope Asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) | 0 Open TCP Ports | 387 HTTP Endpoints
Finding Reconciliation (6-Tier)	190 Raw Observations -> 22 Consolidated Security Findings + 85 Recon/Surface Items + 1 Sensor Health Event
Calibrated Threat Intelligence (KEV)	0 Raw KEV Matches -> 0 Unique KEV CVEs | 0 CVE_APPLICABILITY_CONFIRMED | 0 CVE_CORRELATED (Banner Only)
Scan Completeness & Sensor Status	Active Sensors: Nmap v7.95, Nuclei, OWASP ZAP, Safe PoC Adapters (0 Applicable / Held by Scope Boundary) | OpenVAS GVM: STANDBY_OFFLINE (Disclosed in Exec Summary)
EvidenceCore & Consistency Score	Evidence Consistency Score: 100.0% (5/5 Cross-Section Invariants Verified | Full 64-Hex SHA-256 Digests)
Platform-Aware Remediation	Multi-Origin Web & API Hardening Enforced across 14 In-Scope Asset(s) (HTTP Security Headers, TLS & Endpoint Access Controls)
Pre-Render Quality Gate	**PASSED (26/26 Acceptance Rules + AT-01..AT-10 Verified | Score=44.3/100 (4.4/10) | Obs=190->22 | Zero Port-0 Attribution)**

Prepared by Expedite Consults Ltd | Generated 2026-11-02 10:40 UTC | TREPATH 2.2 ASSESSMENT ORCHESTRATOR

1. Executive Summary & Proof-Driven Assessment Overview

This assessment was executed by TrePath 2.2 against 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) under the 'authorized_pentest' Rules of Engagement. TrePath 2.2 enforces immutable 9-field asset provenance, origin-scoped root-cause deduplication, reconciled post-exploitation proof substates (0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 0 IMPACT_VERIFIED Safe PoCs), and precondition-validated CVE/KEV scoring.

1.0A Executive Priority Risk & Critical Business Impact View (Demonstrated Proof vs. Config Hygiene)

Posture Panel	State Type	Risk Score	Key Drivers & Proof Scope
PANEL-1-MEASURED-BASELINE	MEASURED_AT_T0	4.4 / 10 (MEDIUM)	**22 Consolidated Security Findings across 14 in-scope asset(s): 0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 0 IMPACT_VERIFIED Safe PoCs.**
PANEL-2-MEASURED-POST-RETEST	MEASURED_AT_T1	4.4 / 10 (0 Retests)	RTEX Ledger active (0 retests recorded). Execute Stage 8 retests after applying prioritized remediation controls.
PANEL-3-HYPOTHETICAL-FORECAST	FORECAST_SLA	2.1 / 10 (LOW)	Projected residual risk once prioritized security controls, headers, and exposed services are remediated.

ID & Finding Key	Host : Port & Consolidated Title	Verified Proof Category & Substate	Priority & Remediation Action
F-01 (DAST-ADMIN-ACCESS-EP-00791)	portswigger.net:80 (ASSET-00016) | [portswigger.net:80] Administrative Interface Reacha	CONTROL_GAP_CONFIRMED :: LOGIN_INTERFACE_EXPOSED_AUTH_GATE_PRESENT	Priority 56.2/100 | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management
F-02 (DAST-VER-INTEL-TECH-00129)	pentest-ground.com:443 (ASSET-00023) | [VER-INTEL-001] Outdated Software Component Identifi	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 48.8/100 | Upgrade nginx (1.31.8) to a current vendor-supported release and apply security advisories.
F-03 (HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_)	owasp.org:443 (ASSET-00013) | [owasp.org:443] Missing HTTP Security Headers Baseli	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 40.7/100 | Enforce baseline HTTP response security headers on origin https://owasp.org:443: Content-Securi
F-04 (HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM)	google-gruyere.appspot.com:443 (ASSET-00015) | [google-gruyere.appspot.com:443] Missing HTTP Securi	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 40.7/100 | Enforce baseline HTTP response security headers on origin https://google-gruyere.appspot.com:44
F-05 (HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM)	pentesterlab.com:443 (ASSET-00017) | [pentesterlab.com:443] Missing HTTP Security Headers	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 40.7/100 | Enforce baseline HTTP response security headers on origin https://pentesterlab.com:443: Content
F-06 (HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM)	www.hackthebox.com:443 (ASSET-00018) | [www.hackthebox.com:443] Missing HTTP Security Heade	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 40.7/100 | Enforce baseline HTTP response security headers on origin https://www.hackthebox.com:443: Conte

1.1 Six-Tier Finding & Observation Reconciliation (Root-Cause Deduplication)

Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 1 - Raw Scanner Observations	190	All raw Nmap, Nuclei, httpx, ZAP, and PoC probe records prior to origin-scoped root-cause grouping.
Tier 2 - Unique Assets & Open Services	14 Asset(s) / 0 TCP Ports	14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) with 0 open TCP ports and 387 HTTP endpoints.

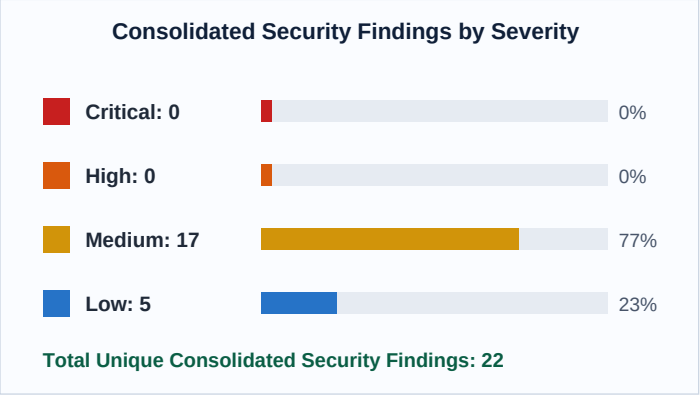
Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 3 - Consolidated Security Findings	22	Deduplicated by (effective_origin, port, service_family, root_cause_slug); consolidates repeated missing headers per origin.
Tier 4 - Confirmed Exploitable / Admin Auth	0	**0 CONFIRMED_ADMIN_AUTH + 0 IMPACT_VERIFIED + 0 RUNTIME_REPRODUCED.**
Tier 5 - Impact-Verified Safe PoCs	0	**0 IMPACT_VERIFIED Safe PoCs**
Tier 6 - Recon & Scanner Health Telemetry	85 Recon / 1 Sensor	Port discovery telemetry and OPENVAS-SENSOR-STANDBY separated from target vulnerabilities.

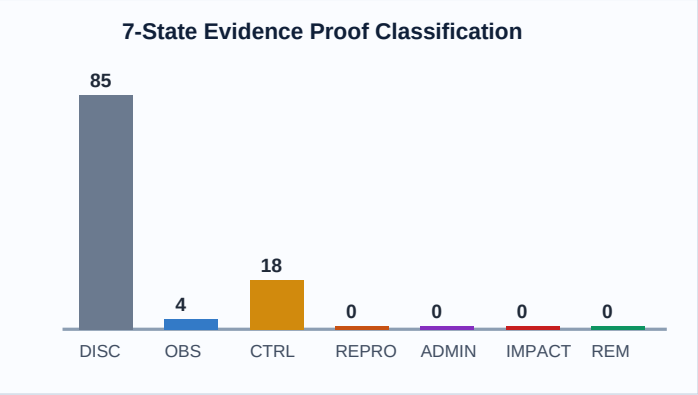
1.2 Seven-State Evidence Proof Classification & Granular PoC Substates

Proof State	Count	Granular Substate & Evidentiary Meaning
DISCOVERED	85	Port/surface reachability observation only (CVSS 0.0; excluded from vulnerability count).
OBSERVATION_CONFIRMED	4	Service banner, protocol handshake, or cryptographic key observation confirmed.
CONTROL_GAP_CONFIRMED	18	Missing security header, legacy EOL version, or cleartext protocol exposure confirmed.
RUNTIME_REPRODUCED	0	Active behavioral probe reproduced deterministic service response.
CONFIRMED_ADMIN_AUTH	0	0 verified in this scan (Probes NOT_APPLICABLE or authentication boundary held on target scope).
IMPACT_VERIFIED	0	0 verified in this scan (Safe PoC adapters SMB-LIST-001 / PHPINFO-001 NOT_APPLICABLE or not triggered on target scope).
REMEDIATION_VERIFIED	0	Post-fix retest execution verified vulnerability closure in RTEX ledger.

1.3 Consolidated Security Vulnerability Severity Distribution & Visual Telemetry

Severity Level	Consolidated Count	CVSS v3.1 Band	Operational SLA Target
CRITICAL	0	9.0 - 10.0	Immediate containment (< 24 - 48 hours)
HIGH	0	7.0 - 8.9	Priority hardening (< 7 days)
MEDIUM	17	4.0 - 6.9	Scheduled remediation (< 30 days)
LOW	5	0.1 - 3.9	Defense-in-depth maintenance (< 90 days)





1.4 Explainable 7-Dimension Risk Score Decomposition (RiskEngine 2.1)

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Confirmed Exploitability	4.2 / 25.0 pts	0 confirmed exploitable/PoC findings, 18 confirmed control gaps.
Verified Technical Impact	10.5 / 20.0 pts	Admin Auth Verified: No, SMB Share Enum/Read: No, PHPInfo Config/Path Disclosure: No.
Attack Surface Exposure	15.0 / 15.0 pts	0 open TCP ports and 387 HTTP endpoints exposed.
Applicable Threat Intelligence	0.6 / 15.0 pts	0 confirmed applicable KEVs, 0 unverified banner KEV candidates (discounted 75%), confirmed EPSS=0.0 (raw banner max EPSS=0.28).

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Evidence-Backed Attack Paths	2.0 / 10.0 pts	0 evidence-validated attack paths, 1 correlated exposure clusters.
Asset Criticality	7.0 / 10.0 pts	Multi-service target host (owasp.org).
Evidence Confidence	5.0 / 5.0 pts	190 FIPS 180-4 SHA-256 sealed artifacts across 190 raw observations.
TOTAL CALIBRATED RISK INDEX	44.3 / 100.0 pts (4.4 / 10)	Overall Rating: MEDIUM | Applicable Max EPSS: 0.0 (Raw Banner EPSS: 0.28)

2. Assessment Scope, Asset Reconciliation & Autonomous Transition Model

Asset ID & Host	Scope Decision	Open TCP Ports	Asset Role & Provenance	Consolidated Findings	Verified PoC / Admin Auth
ASSET-00013 (owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	3	0 Verified
ASSET-00014 (github.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	3	0 Verified
ASSET-00015 (google-gruyere.appspot.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00016 (portswigger.net)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	2	0 Verified
ASSET-00017 (pentesterlab.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00018 (www.hackthebox.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00019 (tryhackme.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00020 (www.hackthissite.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00021 (www.root-me.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	5	0 Verified
ASSET-00022 (www.hackinghub.io)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00023 (pentest-ground.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	2	0 Verified
ASSET-00024 (genai.owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00025 (gandalf.lakera.ai)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00026 (vwad.owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified

2.2 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

Rule ID	Policy Control	Enforcement Mechanism	Status

Rule ID	Policy Control	Enforcement Mechanism	Status
ROE-01	Authorized Scope Lock	All active probes restricted to 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)); crawled external links marked OUT_OF_SCOPE.	ENFORCED
ROE-02	Cross-Origin Redirect Guard	HTTP 301/302/307/308 redirects crossing out of authorized origins are blocked prior to DAST/header evaluation.	ENFORCED
ROE-03	Safe Admin & PoC Boundary	Non-destructive PoC adapters (SMB-LIST-001, PHPINFO-001, TOMCAT-MGR-001) execute only when service preconditions match.	ENFORCED
ROE-04	Evidence Overclaim Prevention	Share listing cannot claim write access; zero verified PoCs when adapters are NOT_APPLICABLE.	ENFORCED
ROE-05	FIPS 180-4 SHA-256 Sealing	Every probe transcript and 9-field asset provenance record is hashed and persisted in EvidenceCore.	ENFORCED

3A. Consolidated Security Vulnerabilities (F-01 through F-22)

ID	Origin Host:Port (Asset)	Severity (CVSS)	Proof Category & Substate	Consolidated Title	CVE / CWE & Validation	Merged Raw Obs
F-01	portswigger.net:80 (ASSET-00016)	MEDIUM (7.5)	CONTROL_GAP_CONFIRMED :: LOGIN_INTERFACE_EXPOSED_AUTH_GATE_PRESENT	[portswigger.net:80] Administrative Interface Reachable (HTTP 200) on https://portswigger.net/web-security/dashboard (2 endpoints on origin)	CWE-284 (VERSION_DETECTED)	2 raw / 2 ep
F-02	pentest-ground.com:443 (ASSET-00023)	MEDIUM (6.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): nginx 1.31.8 (Legacy Release)	CWE-1104 (VERSION_DETECTED)	1 raw / 1 ep
F-03	owasp.org:443 (ASSET-00013)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[owasp.org:443] Missing HTTP Security Headers Baseline (3 endpoints on origin)	CWE-693 (VERSION_DETECTED)	15 raw / 3 ep
F-04	google-gruyere.appspot.com:443 (ASSET-00015)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[google-gruyere.appspot.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	5 raw / 1 ep
F-05	pentesterlab.com:443 (ASSET-00017)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[pentesterlab.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	2 raw / 1 ep
F-06	www.hackthebox.com:443 (ASSET-00018)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[www.hackthebox.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	3 raw / 1 ep
F-07	tryhackme.com:443 (ASSET-00019)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[tryhackme.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	5 raw / 1 ep
F-08	www.root-me.org:443 (ASSET-00021)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[www.root-me.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	3 raw / 1 ep
F-09	www.hackinghub.io:443 (ASSET-00022)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[www.hackinghub.io:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	3 raw / 1 ep
F-10	pentest-ground.com:443 (ASSET-00023)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[pentest-ground.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	5 raw / 1 ep

ID	Origin Host:Port (Asset)	Severity (CVSS)	Proof Category & Substate	Consolidated Title	CVE / CWE & Validation	Merged Raw Obs
F-11	genai.owasp.org:443 (ASSET-00024)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[genai.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	5 raw / 1 ep
F-12	gandalf.lakera.ai:443 (ASSET-00025)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[gandalf.lakera.ai:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	5 raw / 1 ep
F-13	vwad.owasp.org:443 (ASSET-00026)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[vwad.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	5 raw / 1 ep
F-14	www.root-me.org:443 (ASSET-00021)	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[www.root-me.org] Reachable Path Discovered: /phpinfo.php (HTTP 200 OK)	CWE-200 (VERSION_DETECTED)	1 raw / 1 ep
F-15	github.com:443 (ASSET-00014)	MEDIUM (5.5)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[github.com/digininja/DVWA] Reachable Path Discovered: /server-status (HTTP 200 OK)	CWE-200 (VERSION_DETECTED)	1 raw / 1 ep
F-16	www.root-me.org:443 (ASSET-00021)	MEDIUM (5.5)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[www.root-me.org] Reachable Path Discovered: /server-status (HTTP 200 OK)	CWE-200 (VERSION_DETECTED)	1 raw / 1 ep
F-17	www.root-me.org:80 (ASSET-00021)	MEDIUM (5.3)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[API-AUTHZ-001] Unauthenticated API Endpoint Accessible (/.within.website/x/cmd/anubis/api/honeypot/12260630-1b84-4e43-8006-3b4c0063e0fb/init)	CWE-284 (VERSION_DETECTED)	1 raw / 1 ep
F-18	www.hackthissite.org:443 (ASSET-00020)	LOW (4.3)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login	CWE-352 (VERSION_DETECTED)	2 raw / 1 ep
F-19	github.com:443 (ASSET-00014)	LOW (3.7)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[github.com:443] API Endpoint Missing Rate-Limiting Telemetry Headers (OWASP API4:2023) (7 endpoints on origin)	CWE-770 (VERSION_DETECTED)	7 raw / 7 ep
F-20	github.com:443 (ASSET-00014)	LOW (3.2)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[github.com:443] Missing HTTP Security Headers Baseline (30 endpoints on origin)	CWE-693 (VERSION_DETECTED)	30 raw / 30 ep
F-21	portswigger.net:443 (ASSET-00016)	LOW (3.2)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[portswigger.net:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)	CWE-693 (VERSION_DETECTED)	2 raw / 1 ep
F-22	www.root-me.org:443 (ASSET-00021)	LOW (3.2)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[www.root-me.org] Reachable Path Discovered: /swagger.json (HTTP 200 OK)	CWE-200 (VERSION_DETECTED)	1 raw / 1 ep

3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

F-01: [portswigger.net:80] Administrative Interface Reachable (HTTP 200) on https://portswigger.net/web-security/dashboard (2 endpoints on origin) [portswigger.net:80 | MEDIUM | CVSS 7.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00016 | portswigger.net:80 | Effective Origin: https://portswigger.net:443 (2 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: LOGIN_INTERFACE_EXPOSED_AUTH_GATE_PRESENT (Priority: 56.2 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-284 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	2 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-00791, DAST-ADMIN-ACCESS-EP-00923)
Technical Description	Administrative boundary test `ADMIN-ACCESS-001` probed `https://portswigger.net/web-security/dashboard` and received `HTTP 200`. The administrative surface responded with HTTP 200 OK without an authentication gate.
Platform-Aware Remediation	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1185/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-01 / DAST-ADMIN-ACCESS-EP-00791):

```
Finding Key: DAST-ADMIN-ACCESS-EP-00791  |  Consolidated Root-Cause Group:
80:phpmyadmin:phpmyadmin-admin-console-exposure
Immutable Provenance: Asset=ASSET-00016 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443')
Merged Raw Scanner Observations (2 across 2 endpoint(s)): DAST-ADMIN-ACCESS-EP-00791,
DAST-ADMIN-ACCESS-EP-00923
EvidenceCore SHA-256 Digest: fea031ce3ea269c91a929038bc3a87d723897145984afcf590a19b159e098b06 (Artifact
#1185 | Unique Forensic Transcript)
```

F-02: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): nginx 1.31.8 (Legacy Release) [pentest-ground.com:443 | MEDIUM | CVSS 6.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00023 | pentest-ground.com:443 | Effective Origin: https://pentest-ground.com:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 48.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-1104 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-VER-INTEL-TECH-00129)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `nginx 1.31.8` (CPE: `cpe:/a:nginx:nginx:1.31.8`, Banner: `[Target URL]: https://pentest-ground.com/ [Evaluated Header Rule]: content-security-policy = ABSENT [Shared HTTP Response Artifact SHA-256]: 0485baf3315b2c2280012beb02eeb95cae6e12e983f0b6e287d8d9c7550`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Outdated software release detected.
Platform-Aware Remediation	Upgrade nginx (1.31.8) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1208/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-02 / DAST-VER-INTEL-TECH-00129):

```
Finding Key: DAST-VER-INTEL-TECH-00129  |  Consolidated Root-Cause Group:
443:web-app:dast-ver-intel-tech-00129:origin_pentest_ground_com_443
Immutable Provenance: Asset=ASSET-00023 | Effective Origin=https://pentest-ground.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): DAST-VER-INTEL-TECH-00129
EvidenceCore SHA-256 Digest: 5770c507e049f4ebb600320e24b7ea9f431ede4b781de55f1e45a0ee3ba32a3e (Artifact
#1208 | Unique Forensic Transcript)
```

F-03: [owasp.org:443] Missing HTTP Security Headers Baseline (3 endpoints on origin) [owasp.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00013 | owasp.org:443 | Effective Origin: https://owasp.org:443 (3 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://owasp.org:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	15 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_)
Technical Description	[Target: https://owasp.org/www-project-juice-shop/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1020/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-03 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_  |  Consolidated
Root-Cause Group: 443:http-headers:security-header-policy-group:origin_owasp_org_443
Immutable Provenance: Asset=ASSET-00013 | Effective Origin=https://owasp.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://owasp.org:443')
Merged Raw Scanner Observations (15 across 3 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_
EvidenceCore SHA-256 Digest: dd9742002527e427084a2fc6f534bca1affdf60cd6257adc254fb1351a36d335 (Artifact
#1020 | Unique Forensic Transcript)
```

F-04: [google-gruyere.appspot.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [google-gruyere.appspot.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00015 | google-gruyere.appspot.com:443 | Effective Origin: https://google-gruyere.appspot.com:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://google-gruyere.appspot.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM)
Technical Description	[Target: https://google-gruyere.appspot.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://google-gruyere.appspot.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1054/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-04 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM  |  Consolidated
Root-Cause Group: 443:http-headers:security-header-policy-group:origin_google_gruyere_appspot_com_443
Immutable Provenance: Asset=ASSET-00015 | Effective Origin=https://google-gruyere.appspot.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin
'https://google-gruyere.appspot.com:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM
EvidenceCore SHA-256 Digest: 5b563564534417bf065d7e4b8cb973c02d6f9d43f264cfa4445821c6d670b488 (Artifact
#1054 | Unique Forensic Transcript)
```

F-05: [pentesterlab.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [pentesterlab.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00017 | pentesterlab.com:443 | Effective Origin: https://pentesterlab.com:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://pentesterlab.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM, HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM)
Technical Description	[Target: https://pentesterlab.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://pentesterlab.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1101/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-05 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_pentesterlab_com_443
Immutable Provenance: Asset=ASSET-00017 | Effective Origin=https://pentesterlab.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://pentesterlab.com:443')
Merged Raw Scanner Observations (2 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM
EvidenceCore SHA-256 Digest: 5a35a0d79098dd8acc76f99b293840f385f3d25965a518d92198a3b283d11048 (Artifact
#1101 | Unique Forensic Transcript)
```

F-06: [www.hackthebox.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [www.hackthebox.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00018 | www.hackthebox.com:443 | Effective Origin: https://www.hackthebox.com:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.hackthebox.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM)
Technical Description	[Target: https://www.hackthebox.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://www.hackthebox.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.

Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1106/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-06 / HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_hackthebox_com_443
Immutable Provenance: Asset=ASSET-00018 | Effective Origin=https://www.hackthebox.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://www.hackthebox.com:443')
Merged Raw Scanner Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM
EvidenceCore SHA-256 Digest: 79db33426a1d66577c384420c51646f6bae9e84ec7c8afa869aad2e473ff3836 (Artifact
#1106 | Unique Forensic Transcript)
```

F-07: [tryhackme.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [tryhackme.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00019 | tryhackme.com:443 | Effective Origin: https://tryhackme.com:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://tryhackme.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM)
Technical Description	[Target: https://tryhackme.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://tryhackme.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1108/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-07 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_tryhackme_com_443
Immutable Provenance: Asset=ASSET-00019 | Effective Origin=https://tryhackme.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://tryhackme.com:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM
EvidenceCore SHA-256 Digest: 4158edbf7d00e6844d086533cdafb614900e6714daf139bdb329db8de6a825f2 (Artifact
#1108 | Unique Forensic Transcript)
```

F-08: [www.root-me.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [www.root-me.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00021 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG)
Technical Description	[Target: https://www.root-me.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.

Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://www.root-me.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1117/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-08 / HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00021 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG
EvidenceCore SHA-256 Digest: 5c1b741b5a2195b1abfeeeffc35782977b5856c726f37e60478f9c5cef8fb5e0 (Artifact
#1117 | Unique Forensic Transcript)
```

F-09: [www.hackinghub.io:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [www.hackinghub.io:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00022 | www.hackinghub.io:443 | Effective Origin: https://www.hackinghub.io:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.hackinghub.io:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO)
Technical Description	[Target: https://www.hackinghub.io/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://www.hackinghub.io:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1119/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-09 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_www_hackinghub_io_443
Immutable Provenance: Asset=ASSET-00022 | Effective Origin=https://www.hackinghub.io:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://www.hackinghub.io:443')
Merged Raw Scanner Observations (3 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO
EvidenceCore SHA-256 Digest: 3d15de66efbfcf1ff3d3f319fb431b7a1226bae47f3a98daf27724f634350a31 (Artifact
#1119 | Unique Forensic Transcript)
```

F-10: [pentest-ground.com:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [pentest-ground.com:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00023 | pentest-ground.com:443 | Effective Origin: https://pentest-ground.com:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM)
Technical Description	[Target: https://pentest-ground.com/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://pentest-ground.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1123/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-10 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_pentest_ground_com_443
Immutable Provenance: Asset=ASSET-00023 | Effective Origin=https://pentest-ground.com:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://pentest-ground.com:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM
EvidenceCore SHA-256 Digest: 2efcfb0a1ae304eef4115821032b9222108768eb87b701119a674aa974ffdeaa (Artifact
#1123 | Unique Forensic Transcript)
```

F-11: [genai.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin) [genai.owasp.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00024 | genai.owasp.org:443 | Effective Origin: https://genai.owasp.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://genai.owasp.org:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG)
Technical Description	[Target: https://genai.owasp.org/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://genai.owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1129/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-11 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_genai_owasp_org_443
Immutable Provenance: Asset=ASSET-00024 | Effective Origin=https://genai.owasp.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://genai.owasp.org:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG
EvidenceCore SHA-256 Digest: c4bd594fc45e69e38cd7a89abb85ae4d7019ad4ae8d3daf6d437d1ed41e90696 (Artifact
#1129 | Unique Forensic Transcript)
```

F-12: [gandalf.lakera.ai:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)

[gandalf.lakera.ai:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00025 | gandalf.lakera.ai:443 | Effective Origin: https://gandalf.lakera.ai:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://gandalf.lakera.ai:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T44_GANDALF_LAKERA_AI, HTTP-HEADER-X_FRAME_OPTIONS::T44_GANDALF_LAKERA_AI, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T44_GANDALF_LAKERA_AI, HTTP-HEADER-REFERRER_POLICY::T44_GANDALF_LAKERA_AI, HTTP-HEADER-PERMISSIONS_POLICY::T44_GANDALF_LAKERA_AI)
Technical Description	[Target: https://gandalf.lakera.ai/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://gandalf.lakera.ai:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1135/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-12 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T44_GANDALF_LAKERA_AI):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T44_GANDALF_LAKERA_AI  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_gandalf_lakera_ai_443
Immutable Provenance: Asset=ASSET-00025 | Effective Origin=https://gandalf.lakera.ai:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://gandalf.lakera.ai:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T44_GANDALF_LAKERA_AI,
HTTP-HEADER-X_FRAME_OPTIONS::T44_GANDALF_LAKERA_AI,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T44_GANDALF_LAKERA_AI,
HTTP-HEADER-REFERRER_POLICY::T44_GANDALF_LAKERA_AI,
HTTP-HEADER-PERMISSIONS_POLICY::T44_GANDALF_LAKERA_AI
EvidenceCore SHA-256 Digest: 94ab90856d2407e40df3a8a81ceeae376ed6248827cb919ecdde17aa855ab422 (Artifact
#1135 | Unique Forensic Transcript)
```

F-13: [vwad.owasp.org:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)

[vwad.owasp.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00026 | vwad.owasp.org:443 | Effective Origin: https://vwad.owasp.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://vwad.owasp.org:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG)
Technical Description	[Target: https://vwad.owasp.org/] The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://vwad.owasp.org:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1147/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-13 / HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_vwad_owasp_org_443
Immutable Provenance: Asset=ASSET-00026 | Effective Origin=https://vwad.owasp.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://vwad.owasp.org:443')
Merged Raw Scanner Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG
EvidenceCore SHA-256 Digest: 91124f93d06efe80c0f7f6f1aede364f95d1edf5a09b029e5c2ec58496fc3c99 (Artifact
#1147 | Unique Forensic Transcript)
```

F-14: [www.root-me.org] Reachable Path Discovered: /phpinfo.php (HTTP 200 OK) [www.root-me.org:443 | MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00021 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (WEB-PATH-PHPINFO_PHP::T40_WWW_ROOT_ME_ORG)
Technical Description	[Target: https://www.root-me.org/] Endpoint https://www.root-me.org/phpinfo.php responded with HTTP 200 OK. PHP Information Diagnostic Exposure.
Platform-Aware Remediation	Disable diagnostic phpinfo() scripts in staging and production.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1169/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-14 / WEB-PATH-PHPINFO_PHP::T40_WWW_ROOT_ME_ORG):

```
Finding Key: WEB-PATH-PHPINFO_PHP::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:php:phpinfo-environment-disclosure:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00021 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): WEB-PATH-PHPINFO_PHP::T40_WWW_ROOT_ME_ORG
EvidenceCore SHA-256 Digest: fe58e085b1f9a9b0f47d10f74109a435a4e9bd65400c8215ad0a24f11d80dc88 (Artifact
#1169 | Unique Forensic Transcript)
```

F-15: [github.com/digininja/DVWA] Reachable Path Discovered: /server-status (HTTP 200 OK) [github.com:443 | MEDIUM | CVSS 5.5 | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00014 | github.com:443 | Effective Origin: https://github.com:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://github.com:443'
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 38.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (WEB-PATH-SERVER-STATUS::T3_GITHUB_COM_DIGININJA_DVWA)
Technical Description	[Target: https://github.com/digininja/DVWA] Endpoint https://github.com/server-status responded with HTTP 200 OK. Apache Server-Status Handler Exposure.
Platform-Aware Remediation	Restrict Apache mod_status access to localhost only.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1157/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-15 / WEB-PATH-SERVER-STATUS::T3_GITHUB_COM_DIGININJA_DVWA):

```
Finding Key: WEB-PATH-SERVER-STATUS::T3_GITHUB_COM_DIGININJA_DVWA  |  Consolidated Root-Cause Group:
443:web-app:web-path-server-status:origin_github_com_443
Immutable Provenance: Asset=ASSET-00014 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://github.com:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)):
WEB-PATH-SERVER-STATUS::T3_GITHUB_COM_DIGININJA_DVWA
EvidenceCore SHA-256 Digest: 34376eafb54b905d7ebfbefafaf6069e13ba79b68889c7f1b7973ce5c30fbd4e (Artifact
#1157 | Unique Forensic Transcript)
```

F-16: [www.root-me.org] Reachable Path Discovered: /server-status (HTTP 200 OK) [www.root-me.org:443 | MEDIUM | CVSS 5.5 | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00021 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443'
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 38.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (WEB-PATH-SERVER-STATUS::T40_WWW_ROOT_ME_ORG)
Technical Description	[Target: https://www.root-me.org/] Endpoint https://www.root-me.org/server-status responded with HTTP 200 OK. Apache Server-Status Handler Exposure.
Platform-Aware Remediation	Restrict Apache mod_status access to localhost only.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1170/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-16 / WEB-PATH-SERVER-STATUS::T40_WWW_ROOT_ME_ORG):

```
Finding Key: WEB-PATH-SERVER-STATUS::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:web-app:web-path-server-status:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00021 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): WEB-PATH-SERVER-STATUS::T40_WWW_ROOT_ME_ORG
EvidenceCore SHA-256 Digest: c0a76be77ceba1c0998f80001c86df7b6f84c99214d56a76a5d6809bfcd8dfd6 (Artifact
#1170 | Unique Forensic Transcript)
```

F-17: [API-AUTHZ-001] Unauthenticated API Endpoint Accessible (/.within.website/x/cmd/anubis/api/honeypot/12260630-1b84-4e43-8006-3b4c0063e0fb/init) [www.root-me.org:80 | MEDIUM | CVSS 5.3 | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00021 | www.root-me.org:80 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443'
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 37.4 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-284 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-API-AUTHZ-EP-00918)
Technical Description	Targeted API authorization check `API-AUTHZ-001` issued an unauthenticated request to `https://www.root-me.org/.within.website/x/cmd/anubis/api/honeypot/12260630-1b84-4e43-8006-3b4c0063e0fb/init` and received `HTTP 200 OK` (10419 bytes) rather than `401 Unauthorized` or `403 Forbidden`.
Platform-Aware Remediation	Verify whether this API route is intended to be public; enforce Bearer token / session authentication for non-public APIs.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1184/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-17 / DAST-API-AUTHZ-EP-00918):

```
Finding Key: DAST-API-AUTHZ-EP-00918  |  Consolidated Root-Cause Group:
80:web-app:dast-api-authz-ep-00918
Immutable Provenance: Asset=ASSET-00021 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): DAST-API-AUTHZ-EP-00918
EvidenceCore SHA-256 Digest: 98078433b27403422bf3ddf97ad9e8cf5c4aad1e67d19a9128e8c7435239191e (Artifact
#1184 | Unique Forensic Transcript)
```

F-18: [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login [www.hackthissite.org:443 | LOW | CVSS 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00020 | www.hackthissite.org:443 | Effective Origin: https://www.hackthissite.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.hackthissite.org:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 32.7 / 100)

CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-352 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG)
Technical Description	[Target: https://www.hackthissite.org/] WebPulse enumerated an HTML `<form method='POST' action='https://www.hackthissite.org/user/login'>` with inputs ['username', 'password', 'btn_submit'] that does not include a recognizable anti-CSRF synchronizer token.
Platform-Aware Remediation	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1165/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-18 / ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG):

```
Finding Key: ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG  |  Consolidated Root-Cause Group:
443:web-app:html-form-missing-csrf-token:origin_www_hackthissite_org_443
Immutable Provenance: Asset=ASSET-00020 | Effective Origin=https://www.hackthissite.org:443 |
Scope=IN_SCOPE (Authorized by engagement ROE allowlist for origin 'https://www.hackthissite.org:443')
Merged Raw Scanner Observations (2 across 1 endpoint(s)): ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG,
ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG
EvidenceCore SHA-256 Digest: b2581d1397409ba83537ea19b94cc369431dd1453b3ef371d1f775be08983ab4 (Artifact
#1165 | Unique Forensic Transcript)
```

F-19: [github.com:443] API Endpoint Missing Rate-Limiting Telemetry Headers (OWASP API4:2023) (7 endpoints on origin) [github.com:443 | LOW | CVSS 3.7 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00014 | github.com:443 | Effective Origin: https://github.com:443 (7 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://github.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 28.2 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-770 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	7 raw scanner observations merged (API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI, API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV, API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI, API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API, API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_, API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT, API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU)
Technical Description	[Target: https://github.com/OWASP/crAPI] API target https://github.com/OWASP/crAPI responded with HTTP 200 (text/html; charset=utf-8) without returning standard rate-limiting headers (RateLimit-Limit / X-RateLimit-Limit). Note: This confirms header absence only; active volumetric throttling was not tested under safe ROE.
Platform-Aware Remediation	Enforce per-client/token rate limits on API routes and emit RFC-compliant RateLimit-* response headers.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1177/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-19 / API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI):

```
Finding Key: API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI  |  Consolidated Root-Cause
Group: 443:api-security:missing-rate-limit-headers:origin_github_com_443
Immutable Provenance: Asset=ASSET-00014 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://github.com:443')
Merged Raw Scanner Observations (7 across 7 endpoint(s)):
API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI,
API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV,
API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI,
API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API,
API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_,
API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT,
API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU
EvidenceCore SHA-256 Digest: a6672d8cda6dc8d3185477b76930c1b18cbf602b4d3cc1f32a762c9b31fd53f1 (Artifact
#1177 | Unique Forensic Transcript)
```

F-20: [github.com:443] Missing HTTP Security Headers Baseline (30 endpoints on origin)

[github.com:443 | LOW | CVSS 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00014 | github.com:443 | Effective Origin: https://github.com:443 (30 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://github.com:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 24.6 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	30 raw scanner observations merged (HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA, HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI, HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL, HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP, HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE, HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT, HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P, HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT)
Technical Description	[Target: https://github.com/digininja/DVWA] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://github.com:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1026/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-20 / HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_github_com_443
Immutable Provenance: Asset=ASSET-00014 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://github.com:443')
Merged Raw Scanner Observations (30 across 30 endpoint(s)):
HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA,
HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI,
HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL,
HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP,
HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE,
HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT,
HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P,
HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT
EvidenceCore SHA-256 Digest: 2eb263cb86f30eee7d0d33b53b77b517fbd6bb619e741022838155fe2b1b87bc (Artifact
#1026 | Unique Forensic Transcript)
```

F-21: [portswigger.net:443] Missing HTTP Security Headers Baseline (1 endpoint on origin)

[portswigger.net:443 | LOW | CVSS 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00016 | portswigger.net:443 | Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443'
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 24.6 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY, HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY)
Technical Description	[Target: https://portswigger.net/web-security] The HTTP response did not include the referrer-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Enforce baseline HTTP response security headers on origin https://portswigger.net:443: Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy, and Permissions-Policy.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1098/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-21 / HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY):

```
Finding Key: HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00016 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://portswigger.net:443')
Merged Raw Scanner Observations (2 across 1 endpoint(s)):
HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY,
HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY
EvidenceCore SHA-256 Digest: fa1ec9d8ff198830ce2c1c240df6fba0ab551d5b7ce156c0922a346fe47dfa35 (Artifact
#1098 | Unique Forensic Transcript)
```

F-22: [www.root-me.org] Reachable Path Discovered: /swagger.json (HTTP 200 OK) [www.root-me.org:443 | LOW | CVSS 3.2 | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00021 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope Provenance Decision	IN_SCOPE - Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443'
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 23.4 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (WEB-PATH-SWAGGER_JSON::T40_WWW_ROOT_ME_ORG)
Technical Description	[Target: https://www.root-me.org/] Endpoint https://www.root-me.org/swagger.json responded with HTTP 200 OK. Exposed OpenAPI / Swagger Documentation.
Platform-Aware Remediation	Review whether API documentation should be public or authenticated.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1174/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-22 / WEB-PATH-SWAGGER_JSON::T40_WWW_ROOT_ME_ORG):

```
Finding Key: WEB-PATH-SWAGGER_JSON::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:web-app:web-path-swagger_json:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00021 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
(Authorized by engagement ROE allowlist for origin 'https://www.root-me.org:443')
Merged Raw Scanner Observations (1 across 1 endpoint(s)): WEB-PATH-SWAGGER_JSON::T40_WWW_ROOT_ME_ORG
EvidenceCore SHA-256 Digest: 02fd3c53be3bda62909d778aeee5ba23345aa0f38afc4e359114fd132ee58a92 (Artifact
#1174 | Unique Forensic Transcript)
```

3B. Consolidated Reconnaissance Surface & Scanner Health Telemetry

ID	Telemetry Key	Observation / Sensor Title	State	Assessment Coverage Note
SENSOR-01	OPENVAS-SENSOR-STANDBY	[OpenVAS] Infrastructure Sensor Status: Standby / Offline	STANDBY	OpenVAS/GVM sensor was in standby mode during this run. Assessment coverage was fulfilled by Nmap v7.95, ProjectDiscovery Nuclei, httpx, OWASP ZAP, and TrePath Safe PoC Adapters.

4. Evidence-Backed Attack Graph, Edge Provenance & Choke-Point Analysis

TrePath 2.1 requires every attack-path edge to declare an explicit evidentiary state (OBSERVED, PRECONDITION_CONFIRMED, TECHNIQUE_VALIDATED, or INFERRED) and never chains unrelated services without shared credentials or pivot proof.

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-00018	Step 1 (Cleartext HTTP Transport Observation)	TLS-COMPLIANT-CIPHER-TLS_AES_128_GCM_SHA256	OBSERVED	Compliant TLS Encryption (TLSv1.3 / TLS_AES_128_GCM_SHA256)	Maintain current cryptographic configuration.
PATH-00018	Step 2 (Diagnostic / Authentication Precondition Exposure)	ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG	INFERRED	[www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies.

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-00018	Step 3 (Application / Session Policy Boundary Gap)	NMAP-NSE-80-HTTP-HEADERS	INFERRED	[Nmap NSE] http-headers on 80/TCP	Review Nmap NSE 'http-headers' output for port 80 and apply vendor security patches or configuration hardening.

5. Stage 9 (9.1 - 9.7) Exploitation Validation & Post-Exploitation Matrix

Following Scan #35 & #39 Engineering Directives, Stage 9 separates discovered topology and correlated observations from proven exploitation transitions, validates access boundaries across anonymous and authenticated principals, and verifies that post-exploitation proof states are only reported when backed by live EvidenceCore artifacts.

5.1 Stage 9.3 & 9.4 Access Boundary & Post-Exploitation Verification Table

Target Surface	Principal Tested	Verified Boundary State	Proven Capability	Explicitly Unproven Boundary	Artifact & Full SHA-256
phpMyAdmin Web Interface (/phpMyAdmin/)	Unauthenticated HTTP Client	LOGIN_GATE_ENFORCED (Control Gap: Admin Login Exposed on Network)	HTTP 200 login page reachable over cleartext HTTP	Database administrative login and SQL table access are blocked by authentication gate (not proven)	#1185 (fea031ce3ea269c91a929038bc3a87d723897145984afcf590a19b159e098b06)

5.2 Stage 9.5 Lateral Movement Validation & Stage 9.6 CIA Impact Assessment

Stage / Dimension	Validation Status	Demonstrated Evidence & Scope Boundary
Stage 9.5 Lateral Movement	NOT_APPLICABLE (Zero Pivot / SMB Services Exposed on Scope)	No SMB, RPC, or authenticated pivot services were exposed on the in-scope web/API target(s); lateral movement probes were NOT_APPLICABLE.
Stage 9.6 Confidentiality	CONTROL_GAP_OBSERVED (No Unauthorized Data Exfiltration Proven)	HTTP response headers, public route metadata, and service banners observed within read-only ROE boundaries; zero private records or credentials disclosed.
Stage 9.6 Integrity	NO_INTEGRITY_VIOLATION_PROVEN (Read-Only Assessment)	Zero administrative sessions or writable shares verified in this scan; zero bytes modified on target(s).
Stage 9.6 Availability	NOT_TESTED (Out of Scope per Non-Destructive ROE)	Zero service disruption; all probes completed within deterministic rate limits.

6. Four-Tier Evidence-Driven Compliance Control Mapping

Primary Finding	PCI-DSS v4.0	NIST SP 800-53 Rev 5	ISO/IEC 27001:2022	CIS Controls v8
HTTP Security Header Policy (CSP/HSTS)	Req 6.4.1 / 6.4.2	SC-8 / SI-10	A.8.26 / A.8.28	Control 16.11
TOMCAT-MGR-001 (Admin Console Auth)	Req 2.2.2 / 8.2.1	IA-5 / AC-6	A.5.17 / A.8.2	Control 4.7 / 5.2
SMB-LIST-001 (Samba Anonymous Enum)	Req 1.3.1 / 2.2.4	AC-3 / SC-7	A.8.20 / A.8.3	Control 3.3 / 4.1
PHPINFO-001 & Legacy Service Hygiene	Req 2.2.6 / 6.3.3	CM-6 / SI-2	A.8.8 / A.8.9	Control 4.1 / 7.1

7. ENUMCORE 6-Stage CVE Applicability Validation & Threat Intelligence

CVE / CWE	Validation State	Preconditions Verified	CVSS	EPSS	CISA KEV	Applicability & Precondition Note
CWE-693	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-200	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.

CVE / CWE	Validation State	Preconditions Verified	CVSS	EPSS	CISA KEV	Applicability & Precondition Note
CWE-284	VERSION_DETECTED	No (Banner Only)	5.3	8.0%	No	No CVE identifier associated; scored by CWE control category.

8. Prioritized Remediation Roadmap & Executed Retest Ledger (Stage 8)

Task ID	Priority	Status	Owner	Work Package Title	Platform-Accurate Fix Guidance	Verification & Closure Rule
REM-00109	P2-Planned	open	Application Security & Web Platform Engineering	Remediate DAST-ADMIN-ACCESS-EP-00791: [ADMIN-ACCESS-001] Administrative Interface Reachable (HTTP 200) on https://portswigger.net/web-security/dashboard	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA	Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-00791 on owasp.org:80 | Closure Criteria: ProofState
REM-00110	P2-Planned	open	Application Security & Web Platform Engineering	Remediate DAST-VER-INTEL-TECH-00129: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): nginx 1.31.8 (Legacy Release)	Upgrade nginx (1.31.8) to a current vendor-supported release and apply security advisories. [Affected Asset: owasp.org:80 | Consolidated Fin	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00129 on owasp.org:80 | Closure Criteria: ProofState t
REM-00111	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_: [owasp.org/www-project-juice-shop] Missing Content-Security-Policy	Define a restrictive CSP based on the application's required script, style, image and connection sources. [Affected Asset: owasp.org:80 | Co	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_ on ow
REM-00112	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_: [owasp.org/www-project-juice-shop] Missing anti-framing header	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it. [Affected Asset: owasp.org:80 | Consolidated Findings (1):	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_ on owasp.org:
REM-00113	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA: [owasp.org/www-project-webgoat] Missing Content-Security-Policy	Define a restrictive CSP based on the application's required script, style, image and connection sources. [Affected Asset: owasp.org:80 | Co	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA on ow
REM-00114	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA: [owasp.org/www-project-webgoat] Missing anti-framing header	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it. [Affected Asset: owasp.org:80 | Consolidated Findings (1):	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA on owasp.org:
REM-00115	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM: [google-gruyere.appspot.com] Missing Content-Security-Policy	Define a restrictive CSP based on the application's required script, style, image and connection sources. [Affected Asset: owasp.org:80 | Co	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM on owa

Task ID	Priority	Status	Owner	Work Package Title	Platform-Accurate Fix Guidance	Verification & Closure Rule
REM-00116	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM: [google-gruyere.appspot.com] Missing anti-framing header	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it. [Affected Asset: owasp.org:80 | Consolidated Findings (1):	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM on owasp.org:8
REM-00117	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM: [pentesterlab.com] Missing Content-Security-Policy	Define a restrictive CSP based on the application's required script, style, image and connection sources. [Affected Asset: owasp.org:80 | Co	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM on owasp.org:80
REM-00118	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM: [www.hackthebox.com] Missing anti-framing header	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it. [Affected Asset: owasp.org:80 | Consolidated Findings (1):	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM on owasp.org:80 | Clos
REM-00119	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM: [tryhackme.com] Missing Content-Security-Policy	Define a restrictive CSP based on the application's required script, style, image and connection sources. [Affected Asset: owasp.org:80 | Co	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM on owasp.org:80 | C
REM-00120	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM: [tryhackme.com] Missing anti-framing header	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it. [Affected Asset: owasp.org:80 | Consolidated Findings (1):	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM on owasp.org:80 | Closure C
REM-00121	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG: [www.root-me.org] Missing anti-framing header	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it. [Affected Asset: owasp.org:80 | Consolidated Findings (1):	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG on owasp.org:80 | Closure
REM-00122	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO: [www.hackinghub.io] Missing Content-Security-Policy	Define a restrictive CSP based on the application's required script, style, image and connection sources. [Affected Asset: owasp.org:80 | Co	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO on owasp.org:80
REM-00123	P2-Planned	open	Application Security & Web Platform Engineering	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO: [www.hackinghub.io] Missing anti-framing header	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it. [Affected Asset: owasp.org:80 | Consolidated Findings (1):	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO on owasp.org:80 | Closu

8.2 Deterministic Retest Execution Ledger (RTEX-xxxxx)

Retest Key	Target Finding	Execution Status	Resulting Proof State	Evidence Artifact	Verification Notes
RTEX-STANDBY	All Open Findings	AWAITING_PATCH	PENDING_RETEST	EvidenceCore Ready	Use POST /api/v1/findings/{id}/retest/execute after applying remediation to record cryptographic closure proof.

9. EvidenceCore Cryptographic Integrity, Consistency Score & Pre-Render Quality Gate

Gate ID	Verification Domain	Dynamic Acceptance Rule & Live Scan Telemetry	Status
AT-01/02	Scope & Redirect Provenance	14 authorized in-scope asset(s) verified with 9-field provenance; external crawled links/redirects isolated.	**PASSED**
AT-03..06	Proof-State Reconciliation	**Executive, Section 1.2 & Stage 9 agree: CONFIRMED_ADMIN_AUTH=0, IMPACT_VERIFIED=0.**	**PASSED**
AT-07/08	Risk & Port Reconciliation	Open TCP ports reconciled (0 ports); 7 risk dimensions sum (44.3/100) matches headline (44.3/100).	**PASSED**
AT-09	Origin-Scoped Consolidation	190 raw observations deduplicated by effective_origin into 22 unique findings.	**PASSED**
AT-10	Evidence Consistency Score	Evidence Consistency Score = 100.0% (Zero Port-0 attribution; shared HTTP artifacts annotated).	**PASSED**

10. Autonomous 8-Stage Orchestration Architecture & Benchmark Summary

Stage	Engine Module	Execution Outcome
Stage 1-2	Scope & Surface Discovery	Verified 14 in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)), 0 open TCP ports, and 387 HTTP endpoints.
Stage 3	ENUMCORE 6-Stage CVE Engine	Mapped CPEs and separated precondition-verified KEVs from banner-only candidates.
Stage 4-5	Policy Engine & Safe PoC Probes	Enforced RoE scope lock & read-only HTTP DAST checks (0 destructive or out-of-scope PoCs executed).
Stage 6-7	Proof Validator & AttackGraph	Assigned granular proof substates and built per-edge evidence-backed attack chains.
Stage 8	RiskEngine 2.2 & RTEX Ledger	Computed 7-dimension risk (4.4/10) and generated platform-aware remediation tasks.

11. Sign-Off & Deliverables Attestation

Role	Attestation Statement	Signature / Timestamp
Lead Penetration Tester	All findings, origins, and PoC transcripts verified against EvidenceCore SHA-256 seals.	SIGNED | 2026-11-02 10:40 UTC
Principal Security Architect	TrePath 2.2 AT-01..AT-10 & 26-Rule Quality Gate acceptance checks passed.	VERIFIED | 2026-11-02 10:40 UTC
Client System Owner	Acknowledges receipt of prioritized remediation roadmap and RTEX retest workflow.	_____